

DRISHYAM

From Footage to Action

Authentication & Authorization

Login, Roles, Sessions, Protected Routes

Document ID: DRISHYAM-AUTH-001

Version: 1.0 | 13 September 2026

Confidential – For Development Use Only

1. Authentication Flow

Login: POST /auth/login with email + password → returns access_token (short-lived, e.g. 15–60 min) + refresh_token (long-lived, e.g. 7–30 days) + user profile.

Refresh: POST /auth/refresh with refresh_token → new access_token. Refresh tokens rotated on use (recommended).

Logout: Invalidate refresh token server-side (token denylist or family revocation).

2. Password Handling

- Hash with argon2id or bcrypt (cost factor appropriate for hardware)
- Never log or return password hashes
- Password reset via time-limited single-use token sent by email
- Optional: force password change on first login for invited users

3. Roles

SuperAdmin: Platform-level (internal only). Manage all orgs.

OrgAdmin: Full control within one organization: users, sites, cameras, billing settings.

SiteManager: Manage cameras and rules for assigned sites; view and act on alerts.

Operator: View live feeds and alerts for permitted sites; acknowledge / resolve / mark FP.

Viewer: Read-only access to permitted sites and alerts.

4. Authorization Model

Every protected endpoint checks: (1) valid JWT, (2) user is active member of the organization, (3) role permits the action, (4) optional site scope allows the resource.

Implementation: middleware / guards that load membership + role and attach to request context. Resource-level checks (e.g., camera belongs to allowed site) performed in service layer.

5. Session / Token Handling

- Access token: JWT containing user_id, org memberships summary or role claims, exp.
- Refresh token: opaque or JWT stored server-side (or hashed) for revocation.
- Web: prefer httpOnly secure cookie for refresh; access token in memory or short-lived cookie.
- Mobile: secure storage (Keychain / Keystore) for tokens.
- Edge nodes: long-lived service credentials or mTLS, not user JWTs.

6. Protected Routes (Examples)

- All /cameras, /alerts, /sites, /members require authentication.
- Write operations on cameras/sites/members require OrgAdmin or SiteManager.
- Alert action endpoints require Operator or higher.
- Internal /internal/* endpoints require service authentication (API key or mTLS).

7. Invite Flow

OrgAdmin invites by email → system creates pending membership + sends magic link or temporary password → user sets password / accepts → becomes active member with assigned role.